

Date of publication xxxx 00, 0000, date of current version xxxx 00, 0000.

Digital Object Identifier 10.1109/ACCESS.2024.0429000

# An IEC 62443-Based Framework for Secure-by-Design Energy Communities

GIOVANNI BATTISTA GAGGERO<sup>1</sup> (Member, IEEE), ALESSANDRO ARMELLIN (Student Member, IEEE)<sup>1,2</sup>, PAOLA GIRDINIO<sup>1</sup> (Member, IEEE) and MARIO MARCHESE<sup>1</sup>, (Senior Member, IEEE)

<sup>1</sup>Department of Electrical, Electronics and Telecommunications Engineering and Naval Architecture—DITEN, University of Genoa, via Opera Pia 11A, 16145, Genoa, Italy

<sup>2</sup>Iren S.p.A., Via Nubi di Magellano, 30 – 42123 Reggio Emilia, Italy

Corresponding author: Giovanni Gaggero (e-mail: giovanni.gaggero@unige.it).

This work was partially supported by project SERICS (PE00000014) under the MUR National Recovery and Resilience Plan funded by the European Union - NextGenerationEU

**ABSTRACT** The integration of the Renewable Energy Directive II (REDII) into the legislation of European Union member states and the subsequent proliferation of Renewable Energy Communities (REC) has highlighted the need for software platforms to support the administrative, financial, and technical operations of these communities. However, the rise of RECs also introduces significant cybersecurity risks, including financial losses, privacy violations, and broader threats to the stability of the distribution grid. Despite these risks, RECs present a unique opportunity to address cybersecurity concerns from inception, ensuring that security measures are integrated into their design, thereby reducing the complexity and cost of later countermeasures. This paper proposes an IEC 62443-based framework for the secure-by-design development of RECs; after analyzing the risks, the paper proposes a set of guidelines for its mitigation, and validates the proposed approach showing how a REC that respects these guidelines would be compliant with the IEC 62443 standard.

**INDEX TERMS** Energy Community, Security by Design, Cybersecurity, Smart Grid

## I. INTRODUCTION

The Renewable Energy Directive of 2018 (2018/2001/EU) establishes a regulatory framework to foster the use of renewable energy sources and encourage public participation in the energy transition. It introduces innovative approaches such as collective self-consumption schemes (CSCs) and renewable energy communities (RECs), based on the concepts of local energy generation from RES and the communal sharing of this energy. CSCs are designed for users within the same building, whereas RECs are aimed at individuals close to the energy production site. With REDII's incorporation into the laws of European Union member states, RECs have begun to flourish, creating a market need for software platforms that facilitate the administrative, financial, and technical operations of these communities [1] [2]. These platforms manage sensitive data, including real-time electricity usage of REC members, and can control devices like heat pumps and battery energy storage systems. The risk of cyberattacks represents a significant concern, with potential consequences ranging from the disruption of heating systems and infringement on privacy through consumption data analysis to broader threats to the stability of the entire distribution grid if numerous

generators were to be maliciously controlled [3]. Technologies for managing and controlling RECs are evolving, and, despite the few real infrastructures, the number of installed RECs is expected to rise in the next few years [4] [5]. While RECs represent a new vector of attacks on the power system, they also offer a unique opportunity: since they have to be designed for the first time, they can take into account from the very beginning cybersecurity issues, minimizing countermeasures that have to be taken at a later time, reducing their effectiveness and increasing complexity and cost.

This paper proposes a framework for developing secure-by-design energy communities. The main contribution of the paper is a set of guidelines to be respected during the design and deployment phase of the REC; the recommendations take into account both the operational requirements of RECs and the security requirements of the IEC 62443 standard, with the aim of minimizing the cybersecurity risk from the design phase. To the best of our knowledge, this is the first paper in the literature that specifically takes into account the problem of security by design in energy communities. After an analysis of commonly used technologies and commercial

products, the paper analyzes the risk, and provides practical recommendations to mitigate it, following the methodologies provided in the IEC 62443 standard. During the validation phase, we show how, by following the approach proposed in this paper, it is possible to design and deploy a control system that will be compliant with the IEC 62443 standard. The paper also outlines some possible future research directions to further improve the cybersecurity of this technology.

The paper is structured as follows. Section II introduces RECs and discusses the role of web platforms in the management of these infrastructures, analyzing in detail the communication architectures. Section III maps the reference architecture to the IEC 62443 model, defining zones, conduits, and security level targets. Section IV analyzes the risk associated with attacks, taking into account both the implications for the REC's members and the Distribution System Operator (DSO). Section V outlines recommended practices to be followed by RECs designers to reach cybersecurity targets. Section VI validates the recommended practices presented in the previous section by demonstrating how these are sufficient to meet the requirements of the IEC 62443 following the assigned security targets. Section VII discusses some promising research directions to further strengthen the resilience to cyberattacks of these infrastructures. Finally, in Section VIII conclusions are drawn.

## II. RENEWABLE ENERGY COMMUNITIES

### A. REFERENCE ARCHITECTURE

The necessity for robust software platforms to oversee energy communities is undeniable. Reference [1] introduces a web-based system designed for the governance of energy communities, focusing on managing energy prices, grouping end-users, adjusting to price changes, and managing energy demand. Reference [6] emphasizes the critical need for scalable software frameworks that enhance the utility of decentralized renewable resources, including solar panels, storage batteries, electric vehicles, and heating and cooling systems powered by electricity.

Energy Community platforms serve several key functions, including:

- An administrative dashboard that displays the total membership count of the REC and aids in managing the entry and exit of members.
- The capability for real-time oversight of the community's shared energy, along with individual consumption and production metrics, facilitating the alignment of their energy usage with the community's production capabilities.
- A control mechanism that acts as an Energy Management System (EMS) for the REC, optimizing the operation of assets within the community and those owned by members that are integrated with the community's EMS.
- A financial overview that reports the community's earnings from energy sales to the grid and benefits derived from energy sharing among members.

This kind of operation cannot be done without installing dedicated devices at the users' location. There is the need for an object that acts as a local controller for electrical devices, that is able to interface with the EMS on the cloud. The operation of these platforms is supported by data from a 'smart gateway' installed at member locations. This device, a crucial hardware component, connects energy-producing and consuming elements to the platform via the Internet. It communicates with fiscal meters and sensors, collects data, and can control devices with inverters based on commands from the platform's EMS. An overall scheme is shown in Figure 1

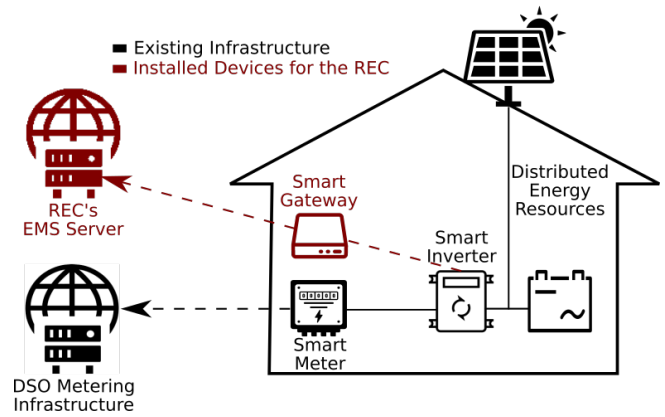


FIGURE 1. Communication Architecture of a REC's member

Below, and in Table 1 we summarized the main commercial products that already implement the architecture that we discussed. An example is the platform Regalgrid [7]; as the producer states, "the Regalgrid® platform gives you access to smart management of your energy resources. The platform dialogues with all types of devices through the SNOCU ([8]), to give you an overview of your energy profile and the correct management of your consumption." The SNOCU controller is the perfect example of smart gateway that allows remote control of the generators (and also the production calls it "smart gateway") ROSE Energy Community [9] is a cloud application for creating, simulating, and managing energy communities, which includes an EMS module and a mobile App to engage participants. ER-LIBRA CE [10] is a cloud solution for the management of Energy Communities and Self-Consumption Group, which includes a control module for the management of storage systems.

| Name            | Company          | Features                                              |
|-----------------|------------------|-------------------------------------------------------|
| Regalgrid       | Regalgrid [7]    | Remote control through the smart Gateway SNOCU [8]    |
| Maps Group      | ROSE [9]         | Cloud application + mobile app for members            |
| Algowatt s.p.a. | ER-LIBRA CE [10] | Cloud application + remote control of storage systems |

TABLE 1. Example of commercial platforms for managing RECs

From now on, we consider the reference architecture for

a smart energy community the one already discussed, which involves the installation of smart gateways at the user's place for remote control.

### B. ATTACK MODEL

With respect to the previously discussed architecture, we can identify three main attack paths: attacks on the communication stack, attacks against the smart gateway, and attacks against the EMS platform

**Attacks on the communication stack.** We can distinguish between two main scenarios: short-range communication and long-range communication. A single prosumer can utilize various types of protocols for communication between the smart meter, the smart gateway, and the field devices, including wireless communication. IoT protocols are known to have certain vulnerabilities [11]; specifically, communication availability can be disrupted through jamming techniques [12]. If an attacker gains access to the power supply, they can also exploit vulnerabilities in power line communication [13]. The primary risks are economic, as breaching local communication could, in the worst case, lead to the control of a small set of devices. The smart gateway can connect to the platform via the LAN or cellular technologies. Security threats vary significantly depending on the mobile communication generation (2G, 2.5G, 3G, 4G, or 5G). One major threat is the potential denial of communication availability. The impact of losing communication between the platform and the smart gateway needs further investigation.

**Attacks on the Smart Gateway.** The Smart Gateway communicates with both control devices and the platform. It may also feature a Human Machine Interface, such as a web application, allowing users to interact with the energy community and access information on energy consumption, billing, etc. Smart Gateways, often being IoT devices with limited computational power, are susceptible to common cyberattacks [14]. There are two primary risks associated with attacks on the smart gateway. First, it can allow the transmission of malicious commands to control devices within the prosumer's perimeter, primarily posing economic risks since only a small set of devices might be affected. Second, a compromised smart gateway can send malicious information to the platform, potentially leading to poor decision-making or platform availability issues. However, it is unlikely that such an attack would threaten the entire distribution grid.

**Attacks on the Platform.** Attacks on the platform are among the most severe threats to Smart Energy Communities. These platforms function as Energy Management Systems, capable of sending setpoints for active and/or reactive power to numerous generators over a large area. Essentially, they operate like SCADA systems for microgrids but differ by using parts of public networks and being directly exposed to the internet. Platforms usually have a dashboard accessible to REC operators for various tasks, thus exposing a web

application to the public internet. Numerous studies have analyzed the vulnerabilities of web servers and common attacks extensively. In Smart Energy Communities, such attacks could significantly impact portions of the electrical power grid, as detailed in section IV. Notably, distribution networks are often not closely monitored, so an attack could persist for an extended period before being detected.

### III. MAPPING RECS ARCHITECTURE TO IEC 62443

Taking into account the reference architecture of a REC, as described in Section II, the first step to project a secure-by-design REC is to evaluate the risk, and define the requirements for the system. We follow the standard IEC 62443, and in particular two parts:

- 62443-3-2 (Security risk assessment for system design), which aim is to define a System Under Consideration (SUC), partition the System Under Consideration into zones and conduits, assess risk for each zone and conduit, and establish the target security level (SL-T) for each zone and conduit
- 62443-3-3 (System security requirements and security levels), which aim is to provide detailed technical control System Requirements (SRs) associated with the seven foundational requirements described in IEC 62443-1-1

We also map the architecture to the Purdue Model. The mapping is done purely by basing on the operational role of the devices, and not on the segmentation of the network. As said, since the control network makes use of portions of the public network, the segmentation paradigm of the Purdue model completely falls. Still, based on the methodology described in IEC 62443, we can identify zones and conduits.

#### A. DEFINITION OF ZONES

The mapping of the REC reference architecture to the Purdue model, and the definition of zones and conduits, is shown in Figure 2

With respect to the Purdue model, we map the reference REC architecture into three layers: generators and loads belong to level 0; smart inverters, meters, and the smart gateway are related to the basic control of the electrical apparatus, and therefore belong to level 1; the EMS platform in practice acts as a SCADA in order to send the setpoints of power, and therefore belongs to level 2-3. As discussed above, this mapping does not correspond to a segmentation of the network. Even, between levels 1 and 2 the communication makes use of the public network.

In order to guarantee the security of the whole system, we follow the IEC 62443 procedure to analyze the risk and recommend proper cybersecurity countermeasures. The first step is to define the Zones and the conduits. As defined in the standard, a *security zone is a physical/logical grouping of physical, informational, and application assets sharing common security requirements*. With respect to Figure 2, we identify two main zones:

- Zone 1: it includes the local network that connects all the assets related to local control. The devices are: the

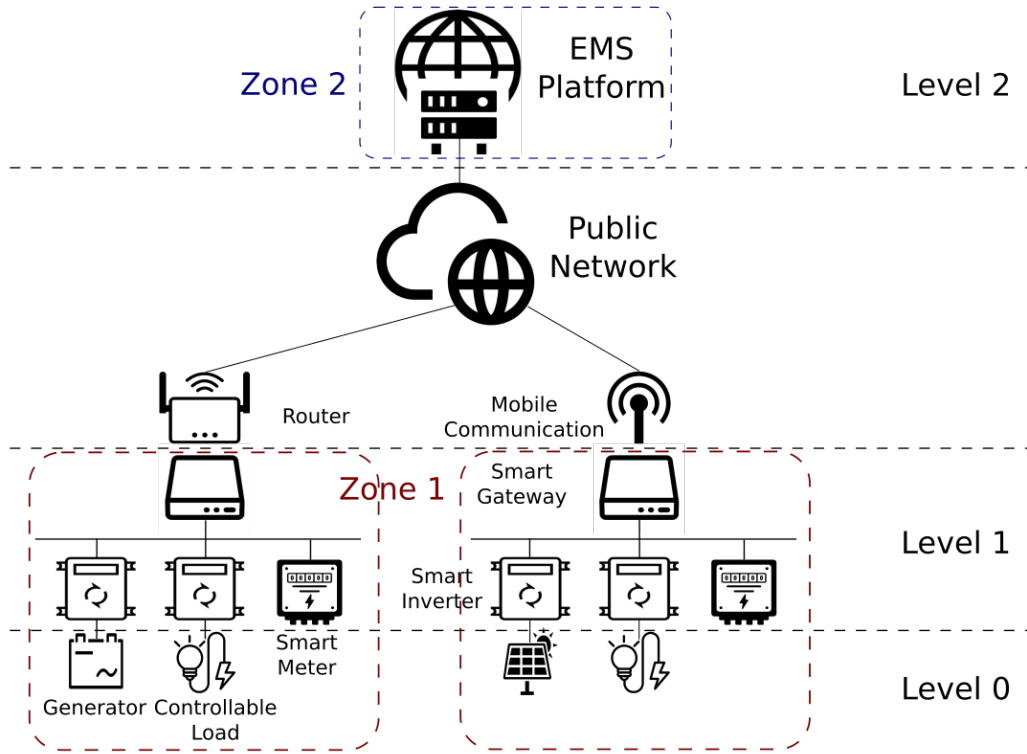


FIGURE 2. Mapping REC Reference Architecture to the Purdue Model

smart gateway, the smart meter, and all the smart inverters that control generators and/or loads of the REC. The rationale is that all the devices contribute to the control of a single prosumer, and therefore share security requirements.

- Zone 2: it includes the centralized platform for the remote control. The server has been included in another zone because it is physically dislocated with respect to the other devices, and the compromise of the central platform is obviously more serious than the compromise of a single prosumer.

As defined in the standard, a conduit is a logical or physical grouping of communication channels connecting two or more zones that share common security requirements.. In the previously described scenario, the conduit is represented by the public internet.

#### B. ASSIGNMENT OF SECURITY LEVELS

The next step is to define the Security Level Target (SLT) for the identified zones. With respect to the two previously described zones, we assign the following SLT:

- Zone 1 → SL-2 - *Protection against intentional misuse by simple means with few resources, general skills and low motivation:* the rationale beyond this choice is that a compromise of this zone would only affect a single prosumer, and mostly on an economic level, as it will be discussed in section IV

- Zone 2 → SL-3 - *Protection against intentional misuse by sophisticated means with moderate resources, IACS-specific knowledge, and moderate motivation:* the rationale beyond this choice is that a compromise of this zone would affect the whole REC, and potentially also the distribution grid in which it is implemented, as it will be discussed in section IV

Section IV motivates the choice of the SLT, while in Section V we propose possible countermeasures to reach the SLTs.

### IV. RISK ASSESSMENT FOR RECS

#### A. RISK FOR REC MEMBERS

As discussed, an attack can enable the transmission of harmful commands to control devices within the prosumer's perimeter. In this scenario, from the electricity supply perspective, the risks are primarily associated with economic damages, as an attack would likely affect only a limited number of devices. A further risk is related to privacy. It has been already investigated in the literature how the energy consumption data collected by Advanced Metering Infrastructures (AMI) are considered sensitive consumer information [15]. Research shows how distributed smart metering data can provide detailed insights into the activities within a household [16]. Some studies propose privacy-preserving data release techniques for smart meters [17].

While some considerations can be extended also to the case of RECS, further studies have to be done in this field. Therefore, privacy is a critical concern and poses a significant



barrier to the real-time collection of this data.

## B. RISK FOR THE DSO

The capacity of a single EMS platform to regulate a vast number of generators and/or controllable loads within the distribution grid represents a risk for the whole grid. It is possible that a successful cyberattack, able to manipulate all the generators and loads of the single REC, could not only inflict economic losses but might also disrupt the functioning of the power grid. These devices share unique characteristics, such as being located under a single substation within energy communities.

The impact of cyberattacks on the main grid has been investigated in the state of the art. [18] outlined a scenario where a cyberattack targets DERs, altering the power output to induce oscillations or instability. However, they did not deeply explore how DER locations could be exploited for greater impact. [19] examined the consequences of controlling numerous DERs, particularly focusing on storage systems. [20] demonstrated potential violations of voltage limits via cyberattacks on DERs within the CIGRE medium voltage benchmark grid. Reference [21] examined the effect of an Electric Vehicle botnet attack on both the IEEE 33-bus distribution network and an IEEE 39-bus transmission model, highlighting the significant disruptions such an attack could cause. Reference [22] showcased how manipulating actual load demand within an IEEE 9-bus system could demonstrate the negative outcomes of similar cyberattacks, stressing the vulnerability of power systems to targeted manipulations. A detailed investigation into the security of EV charging infrastructure [23] assessed the power system's vulnerability to attacks targeting EVs, with simulations revealing potential system oscillations and quantifying risks to Distributed Energy Resources equipment. [24] explored the consequences of Internet of Things (IoT)-enabled cyberattacks on both transmission and distribution grids, indicating the increasing threat landscape due to the interconnected nature of these systems. [25] explored how attacks on power system frequency could cause significant disruptions, including load shedding and outages, by inducing scenarios where the frequency drops below 59.5 Hz or rises above 61.5 Hz, which are critical thresholds for system stability. [26] discussed the potential for coordinated attacks on a large number of EV charging points to lead to significant power grid disruptions. An assessment of the impact on economic losses, reliability indices, voltage stability, and power losses within a distribution network was conducted in [27], utilizing a simulated IEEE 33-bus system to understand the breadth of potential consequences from such cyberattacks. [28] analyzed the impact of cyberattacks on low voltage distribution systems, specifically focusing on Electric Vehicles Charging Systems. This study pointed out that while electric vehicles can be integrated into Renewable Energy Communities (RECs), the profile and control of power within a specific area for energy communities change significantly, necessitating dedicated analysis to understand the unique risks involved. Up to now, the only work that

specifically took into account RECs is [29], which simulates the impact of an attack on a REC bot at the low and medium voltage level; while further research has to be done, this paper clearly shows how attacks on RECs can alter the normal functioning of the distribution grid.

## V. RECOMMENDED PRACTICES AND GUIDELINES

Defense-in-depth is a comprehensive cybersecurity strategy for industrial control systems that employ multiple layers of defense to ensure robust protection. We base our recommendation on four main pillars: segmentation and perimeter defense, communication security, host security, and cybersecurity monitoring.

### A. SEGMENTATION AND PERIMETER DEFENSE

**C A.1 Create a sub-network for the prosumer control devices.** At levels 1 and 0, the implementation of segregation is more challenging due to the connectivity that is often offered by the assets. Consequently, it is often necessary to extend a dedicated sub-network encompassing both level 0 and level 1 assets. In case the control network exploits the home network, it is recommended to create two different subnetworks and limit the access of the users to the control network.

**C A.2 Limit the wireless communication to the control network devices.** The implementation of any wireless process network should be limited and eventually monitored. The use of wireless communication is not recommended for process networks. It is recommended not to adopt the private wireless network of the users for process control. This network should always be separated from any other network. Usually, users have direct access to the inverter to obtain information regarding the energy produced; to guarantee the segmentation, it is recommended that the final user can connect only to the web server of the platform.

**C A.3 Configure a Firewall between the prosumer control network and the internet.** It is recommended to install a firewall between the control network and the other networks (e.g. the home network and the public internet). That could be represented by the home router. The firewall should allow the remote connection to the smart gateway only from the EMS platform and should deny non-necessary communication between the home users and the control network.

### B. COMMUNICATION SECURITY

**C B.1 Provide authentication between the smart gateway and the EMS platform.** Ensuring secure communication between a control server and IoT devices over the public internet necessitates robust authentication mechanisms. Authentication is critical to verify the identity of both the server and the IoT devices, preventing unauthorized access and potential security breaches. Mutual authentication is essential, where both the control server and the IoT devices authenticate each other. This is often achieved using digital

certificates and Public Key Infrastructure (PKI), where each device and server has a unique certificate issued by a trusted Certificate Authority (CA), helping verify their identities. Secure communication protocols such as Transport Layer Security (TLS) are also used to ensure that data transmitted between the server and the devices is encrypted. TLS provides mechanisms for certificate-based authentication, further enhancing security. For simpler devices or constrained environments, pre-shared keys (PSK) may be used. In this method, both the control server and the IoT device have a secret key that is used to authenticate each other. This method is less flexible than PKI but can be effective for specific use cases. In more complex environments, OAuth and token-based authentication can be used to grant temporary access tokens to devices. These tokens, issued by an authentication server, have a limited lifespan, reducing the risk of long-term key exposure. Additionally, device certificates and firmware signing can be used, which ensure that IoT devices run authenticated firmware and software.

### C B.2 Provide end-to-end cryptography for the communication between the smart gateway and the EMS Server.

End-to-end cryptography in industrial systems ensures that data is encrypted from the point of origin to the final destination, preventing unauthorized access or tampering during transmission. This requirement is crucial for protecting sensitive information exchanged between devices, controllers, and monitoring systems within the industrial automation and control environment. In the REC scenario, it is recommended to guarantee end-to-end cryptography between the smart gateway and the EMS platform. In case the smart gateway exploits the home network to access the public internet, this can be achieved through well-known techniques. In case the communication is wireless, the optimal solution to achieve this countermeasure is the establishment of a private Access Point Name (APN) communication between each smart gateway and the EMS platform. The implementation of this communication type ensures the security of end-to-end communication across the public network.

**C B.3 Provide authentication on the web server.** The EMS platform exposes to the public internet a web server. On this server, the data regarding the REC, such as energy and economic profiles, are collected to be consulted by REC members and supervisors. At least three main user profiles are identified. The first user profile belongs to the typical member of the REC, who should be able to access the aforementioned data, energy profiles as a consumer and as a prosumer, the comprehensive profile of the entire REC, and the economic profiles. The second user profile is intended for the chairman of the REC, who should be able to access all the aforementioned profiles for each client. The third profile is intended for the operators of the REC. In addition to the aforementioned profiles, they should have access to other specific custom profiles. Furthermore, it is possible that they may gain access to numerous RECs with identical credentials.

The authentication policy should be obligatory for all three profiles, although there may be some discrepancies.

## C. HOST SECURITY

**C C.1 Separate the machine for remote control of the DERs from the one for user access and close all ancillary services on the EMS control server.** The EMS platform could be further divided into different zones, according to the IEC 62443 Standard recommendations. Following the Purdue Model, the EMS engine is analogous to a conventional supervisory and control system, such as a Supervisory and Data Acquisition System (SCADA), and thus falls within the third level of the Purdue Model. In light of the aforementioned considerations, it seems to be correct to view the EMS engine as a legitimate operational technology (OT) asset. In traditional architectures, it is advised to not expose the EMS engine to the public internet. Nevertheless, an operational constraint is that the EMS platform should be accessible via the public internet, at least for the purpose of data consultation by REC members and operators. Therefore, the first step is to separate these functions into two different servers, that communicate following the advice of the next point.

**C C.2 Create a Demilitarized zone between the EMS control server and the web server.** The proposed approach is illustrated in Figure 3, which depicts the EMS platform divided into two main parts: the EMS Web Server and the EMS Engine. The EMS web server is located at level 4 of the Purdue Model, within the IT department. This server can be exposed to the public internet with the appropriate configurations, including a firewall and authentication. The EMS engine is located in a dedicated OT network area required exclusively for the supervision and control of the REC. The EMS engine is the most critical part of the entire EMS platform because it is directly connected to the industrial field and can control the behavior of the REC. In the middle of the EMS engine and the EMS web server, separated by a firewall on both sides that guarantees segregation and visibility, there is the so-called *industrial Demilitarised Zone (iDMZ)*. The purpose of this area is to decouple the OT environment from the IT environment, thus ensuring a high level of segregation. This area contains the *Exchange Data Server*, shown in Figure 3 is located. Other cybersecurity services such as remote access, updating, or authentication are eventually located in this area. These services are not mandatory and may vary from vendor to vendor. An example of implementation of this logical scheme is shown in Figure 4, where all the communication passes through a single firewall, that allows the communication as described above.

The implementation of DMZ between the corporate network and control network through a central firewall is clearly explained in the NIST 800-82 Guide to Industrial Control Systems Security [30]. In the REC use case, the web server is connected to the corporate network, while the EMS belongs to the control network.

**C C.3 Allow only admin users to access devices on**

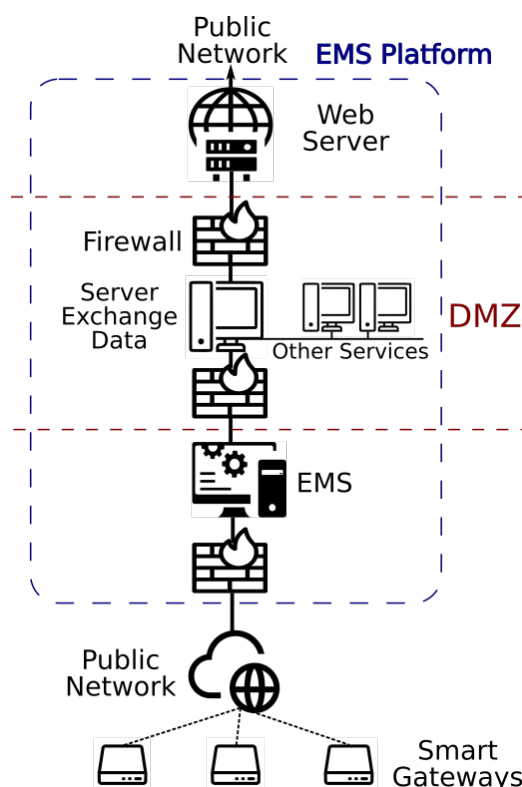


FIGURE 3. EMS Platform - Logical Scheme

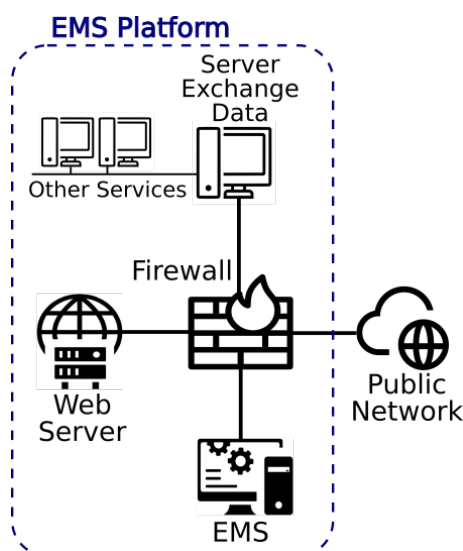


FIGURE 4. EMS Platform - Example of Implementation

**the control network.** The control network is composed of the area where the EMS engine is located and the network between the smart gateway and the field devices. Figure 3 shows this as level 3 of the Purdue Model.

As pointed out in subsection V-A, the control network at the local level makes use of a dedicated subnetwork. Since we have to respect this segmentation, it is reasonable that only admins and automation engineers should have access to this area. Therefore, direct communication between control devices (such as smart inverters) and final users should not be allowed.

The EMS platform is the most critical part of the control network because access to the EMS engine allows full control of the entire REC. The consequence of malicious access at this level could not only cause economic damage but also electrical grid instability, affecting many customers even outside the REC. The implementation of strong authentication policies with the adoption of MFA should be mandatory for local access to this level but usually remote access is necessary to ensure proper operation and the best support. The most common solution adopted in these scenarios is the decoupling of the remote access. The remote access service is one of the other services belonging to the DMZ as shown in Figure 3. The remote access service consists, for example, of a Virtual Desktop Infrastructure (VDI). In this configuration, the remote access follows this sequence: 1) The remote user reaches the Remote service using a proper Virtual Private Network (VPN), properly configured; 2) The remote user authenticates on the VDI service. A new, properly profiled VDI is launched. 3) The remote user can access the EMS engine profiled to the corresponding VDI. This configuration guarantees complete decoupling of remote access to the EMS engine.

**C C.4 Verify best practices of software development for the smart gateway.** Developing secure software for IoT devices requires adherence to stringent guidelines and best practices to mitigate risks and ensure robust protection. The National Institute of Standards and Technology (NIST) provides a comprehensive framework, particularly outlined in NIST SP 800-53 and NISTIR 8259A, which offer detailed controls and recommendations specifically tailored for IoT security. These frameworks emphasize the importance of incorporating security at every stage of the software development lifecycle, from initial design to deployment and maintenance. Also, the IEC 62443 provides specific guidance on cybersecurity for industrial automation and control systems, ensuring that IoT devices within these environments are designed and operated securely. Key practices recommended by these guidelines include conducting thorough threat modeling, implementing secure coding practices, performing regular security testing and vulnerability assessments, and ensuring proper authentication and access control mechanisms. Additionally, maintaining detailed logs and monitoring for anomalies is crucial for ongoing security management.

## D. CYBERSECURITY MONITORING

**C D.1 Generate security logs on the EMS platform.** To ensure comprehensive cybersecurity monitoring for a platform comprising a web server for communication with end-users and a control server connected through a demilitarized zone, it is essential to collect and send various types of logs to a Security Information and Event Management (SIEM) system. Firstly, web server logs are crucial. These logs include HTTP access logs, which record every request made to the web server along with details like IP addresses, timestamps, requested URLs, and response codes. Additionally, error logs capture issues encountered by the server, such as failed requests or server-side errors. These logs help detect and analyze potential web-based attacks, such as SQL injection or cross-site scripting. Application logs from the web server and any web applications running on it are also important. These logs provide detailed information about application usage, performance, and errors, enabling the detection of application-layer vulnerabilities and anomalous behavior. Authentication logs are another key type of log to collect. These logs record successful and failed login attempts, password changes, and other authentication-related events. They are essential for identifying unauthorized access attempts and potential credential-stuffing attacks. System logs from both the web server and the control server provide information about system-level events such as boot sequences, process starts and stops, and system errors. These logs are useful for detecting system anomalies and potential compromises at the operating system level. Network logs are critical in a DMZ setup. These include firewall logs, which track allowed and denied traffic based on firewall rules, and Intrusion Detection/Prevention System (IDS/IPS) logs, which provide alerts on suspicious or malicious network activity. These logs help in monitoring and protecting the traffic flow between the web server, the control server, and the end-users. Security event logs capture specific security-related events such as antivirus or EDR/XDR alerts, file integrity monitoring events, and other security tool outputs. Lastly, audit logs track administrative actions and configuration changes on both servers. These logs are crucial for ensuring accountability and traceability, helping to investigate any changes that could potentially compromise security. By collecting and sending these logs to a SIEM system, organizations can achieve comprehensive visibility into their platform's security posture, enabling effective detection, analysis, and response to potential threats.

**C D.2 Generate security logs on the Smart Gateway** To ensure robust cybersecurity for an IoT device used for remote control, such as the smart gateway, it is essential to collect a variety of logs that capture different aspects of its operation and interaction with other systems. These should include: authentication logs, that record attempts to access the device, including both successful and failed login attempts; system logs, that track the internal operations of the IoT

device, including boot sequences, system errors, and updates; network logs, that provide details of the network activity, including incoming and outgoing connections, data transfers, and communication with other devices or servers; application logs, that capture the activities of the applications running on the smart gateway, providing insights into application usage; audit logs, that track administrative actions, and configuration changes made to the device, ensuring accountability and traceability of changes

**C D.3 Collect the logs generated by the EMS platform and the smart gateway in a central platform.** Typically, the central platform for collecting, analyzing, and correlating security logs is a SIEM system located in the IT department. The SIEM is one of the core platforms of the Security Operation Center (SOC), the team of security analysts who manage cybersecurity events and incidents. In short, a SIEM platform generates alerts through correlation rules and allows analysts to access many logs to perform their analysis and reporting. The log collector service is one of the *other services* belonging to the iDMZ as shown in Figure 3. The generation of security and audit logs is a critical requirement for the EMS platform. The next step is to collect these logs in a single platform. For the OT log, this task is required for the log collector service located in the iDMZ. The owner of the SIEM platform should be the provider of the EMS platform, as they have the knowledge of the entire infrastructure and the nature of the logs.

## VI. VALIDATION

The validation of the proposed approach is pursued through two phases. In subsection VI-A we analyze studies that quantitatively proved the effectiveness of the IEC 62443 standard in mitigating the risk in the power sector. In subsection VI-B we show how the set of recommendations would allow making an Energy Community compliant by design. Finally, subsection VI-C discusses the limitations of this study and proposes some solutions to address them.

### A. EFFECTIVENESS OF IEC 62443 IN THE POWER SECTOR

[31] provides a review of existing cybersecurity standards for the smart grid environment. The IEC 62443 is identified as one of the main standards for the power sector, as well as a baseline for more specific standards, such as IEC 62351. [32] introduces a conceptual framework for representing and monitoring adherence to security requirements, aligning with commonly adopted security standards; the model, presented as a Unified Modeling Language (UML) class diagram, aims to provide product providers with a standardized approach to map requirements from various standards, guidelines, and regulations, expediting cross-standard compliance; in particular, it focuses on simultaneous alignment with three standards—NISTIR 7628, NIST 800-53, and IEC 62443-3-3, showing evident similarities for smart grids.

Moreover, the IEC 62443 standard is commonly used in the power sector, and particularly has been investigated in the



state of the art for similar technologies involving DERs, as the reference standard for risk assessment, such as in:

- Microgrids: [33] presents a comprehensive methodology for applying STRIDE to cyber-physical systems and illustrates its effectiveness through a case study of a microgrid system. The threat modeling outcomes are used to identify security requirements within the context of the IEC 62443 standard.
- Virtual Power Plants: [34] demonstrates a practical implementation of the NESCOR threat assessment methodology for Virtual Power Plants. Complementary to standardized information risk assessments, this method can be applied concurrently during either the initial or detailed phases of the IEC 62443 process.
- Distribution substations: [35] concludes that the various components of the IEC 62443 standard can be effectively applied to the operational technology domain of critical infrastructure by distribution system operators DSOs to address cybersecurity requirements, and specifically to digital substations.
- Big-size generators: [36] analyzes the application of IEC 62443 concepts for hydro-electrical power plants
- Smart local energy systems: [37] presents an extensive investigation into existing technical standards to analyze how they address cybersecurity issues in smart local energy systems, which present similarities to microgrids and Virtual Power Plants.

Moreover, the Sandia report [38] recommends IEC 62443 for managing patches in DERs. For this reason, it seems natural to extend the usage of the same standard to the recent technology of energy communities.

### B. MAPPING TO IEC 62443 FR

Table 2 maps the suggested countermeasures to the Fundamental Requirements of IEC 62443. If all the countermeasures are implemented, this framework allows making the REC compliant with the IEC 62443 standard with respect to the architecture described in Section II-A and the Zones defined in Section III from the design phase.

It can be noticed how all the Fundamental Requirements are satisfied by the proposed countermeasures for both the zones. For this reason, the proposed set of countermeasures allows the energy community designer to build a secure system from the design phase, therefore improving the overall security posture and reducing the effort for making the system secure retrospectively. Appendix A details one-by-one the Security Requirements and the specific countermeasures that allow us to respect them.

### C. DISCUSSION

The rapid increase in DER devices and their expected growth highlights the importance of robust security practices. To fully leverage the benefits of DERs while addressing the associated security challenges, collaboration between security engineers, industry professionals, and academic researchers is crucial [39].

The validation of the proposed approach posed significant challenges. The key limitation resides in the limited number of real RECs systems up to now, and their very recent implementation. For this reason, it is difficult to dispose of real data regarding attack models; even more difficult is to dispose of quantitative data regarding the number of successful attacks in both cases (compliance to the standard and not). At the same time, this is the main reason why it is important to dispose of frameworks for secure-by-design implementations. To overcome this issue, we decided to analyze the effectiveness of the standard in the power sector through an analysis of the state of the art, and subsequently to demonstrate that the set of recommendations guarantees adherence to the standard. While limited, we believe that this validation was the best possible method, and is enough to recommend the implementation of IEC 62443 standards in the new REC systems. Future works will analyze data coming from real infrastructures, in order to quantitatively assess the risk mitigation in these specific infrastructures.

### VII. FUTURE RESEARCH DIRECTIONS

Some novel technologies could be applied to the cybersecurity of smart energy communities. We identified some key topics, that answer different needs, from communication security to monitoring and attack response.

- Communication Security: the application of blockchain technology within energy communities has been predominantly explored for the development of peer-to-peer energy trading systems, with limited research extending beyond this scope [40]. However, the intrinsic characteristics of blockchain and ledger-based technologies offer the potential for securing the remote control and coordination of distributed energy resources (DERs), such as generators, energy storage systems, and flexible loads. For instance [41] demonstrates the use of smart contracts to manage battery energy storage systems. Additionally, blockchain can enhance the platform's authentication mechanisms for securing monitoring data. [42] propose a privacy-preserving and data aggregation system based on blockchain to safeguard consumer privacy during smart meter readings.
- Resilience to attack and Graceful Degradation: decentralized control offers several key advantages to the cybersecurity of smart energy communities; decentralized systems are less vulnerable to single points of failure, such as the EMS server, so that if one node or component is compromised, the rest of the system can continue to function, thereby reducing the risk of widespread disruptions. Some examples can already be found in the literature. [43] suggests a blockchain-powered decentralized energy market to facilitate the creation and growth of citizen energy communities. [44] introduces a decentralized demand response system for energy communities that utilizes blockchain technology and peer-to-peer energy flexibility trading.

**TABLE 2. Mapping Countermeasure with Fundamental Requirements**

|                                                  | Zone 1                 | Zone 2                     |
|--------------------------------------------------|------------------------|----------------------------|
| FR 1 – Identification and authentication control | A2, C3, C4             | A2, B1, B3, C2, C3         |
| FR 2 – Use control                               | A2, A3, C3, C4, D2     | A2, C2, C3                 |
| FR 3 – System integrity                          | A1, A3, C2, C4, D2, D3 | B1, B2, C1, C2, C3, D1, D3 |
| FR 4 – Data confidentiality                      | B1, B2, C4             | B1, B2, B3, C3             |
| FR 5 – Restricted data flow                      | A1, A2, A3             | C1, C2, C3                 |
| FR 6 – Timely response to events                 | D2, D3                 | D1, D3                     |
| FR 7 – Resource availability                     | A1, A3, C4, D2         | C1, C2, D1                 |

- Security Monitoring: An intrusion detection system that exclusively monitors network traffic may be inadequate for identifying certain types of attacks [45]. For distributed energy resources (DERs), it is crucial to detect attacks from both cyber and physical perspectives [46]. Cyber attacks on industrial systems aim to alter the physical behavior of the processes, so physics-based anomaly detection systems focus on monitoring process measurements. The goal is to alert users before an attack can significantly impact the process. A comprehensive review of physics-based anomaly detection methods is provided by [47]. These approaches have to be customized to the specific use case of a REC.
- Attack Response: while, as discussed above, DER's attacks can severely disrupt the power grid, typically there are no automatic responses; instead, cyber defense is usually handled manually, despite the fast dynamics of the power system. [48] explores the potential of integrating cybersecurity functions into electrical protection mechanisms as an attack-response tool. By enabling electrical protections to trip upon detecting an ongoing attack, these functions aim to ensure the continuity of the power system during cyberattacks. Nevertheless, this approach must be tested in different scenarios and with a deeper performance analysis.

## VIII. CONCLUSIONS

This paper has presented a comprehensive framework for developing secure-by-design renewable energy communities. Our analysis highlights the critical importance of integrating cybersecurity measures from the initial design stages of RECs to preempt potential vulnerabilities and mitigate risks effectively. Through a detailed examination of commonly used technologies and commercial products, we have mapped the reference architecture of RECs to the IEC 62443 standard. This mapping process involved defining zones, conduits, and security-level targets. The practical recommendations outlined in this paper offer clear guidelines for REC designers, enabling them to achieve the defined cybersecurity targets. These recommended practices were validated against the IEC 62443 requirements, demonstrating their sufficiency in meeting the prescribed security targets and ensuring the resilience of RECs to cyber threats. In addition to addressing current security concerns, this paper has identified several promising research directions to further enhance the cybersecurity of RECs.

In conclusion, as RECs continue to proliferate across the European Union, it is imperative to prioritize cybersecurity from the outset. By adopting the secure-by-design approach detailed in this paper, stakeholders can safeguard the stability and privacy of RECs, fostering a secure and sustainable energy transition.

## APPENDIX A MAPPING TO FUNDAMENTAL REQUIREMENTS REFERENCES

- [1] H. Pereira, L. Gomes, P. Faria, Z. Vale, and C. Coelho, "Web-based platform for the management of citizen energy communities and their members," *Energy Informatics*, vol. 4, no. 2, pp. 1–17, 2021.
- [2] A. Bonfiglio, S. Bruno, M. Martino, M. Minetti, R. Procopio, and A. Velini, "Renewable energy communities virtual islanding: A novel service for smart distribution networks," in *2024 IEEE/IAS 60th Industrial and Commercial Power Systems Technical Conference (I&CPS)*. IEEE, 2024, pp. 1–8.
- [3] G. B. Gaggero, D. Piserà, P. Girdinio, F. Silvestro, and M. Marchese, "Novel cybersecurity issues in smart energy communities," in *2023 1st International Conference on Advanced Innovations in Smart Cities (ICAISC)*. IEEE, 2023, pp. 1–6.
- [4] E. Barabino, D. Fioriti, E. Guerrazzi, I. Mariuzzo, D. Poli, M. Raugi, E. Razaei, E. Schito, and D. Thomopoulos, "Energy communities: A review on trends, energy system modelling, business models, and optimisation objectives," *Sustainable Energy, Grids and Networks*, vol. 36, p. 101187, 2023.
- [5] I. F. Reis, I. Gonçalves, M. A. Lopes, and C. H. Antunes, "Business models for energy communities: A review of key issues and trends," *Renewable and Sustainable Energy Reviews*, vol. 144, p. 111013, 2021.
- [6] C. Chudoba and T. Borges, "Platform-based energy communities in germany and their benefits and challenges," in *Energy Communities*. Elsevier, 2022, pp. 385–397.
- [7] "Regalgrid - the platform," 2024, <https://www.regalgrid.com/en/the-platform/> [Accessed: 04/2024].
- [8] "Snocu controller - smart gateway per il monitoraggio e controllo delle proprie risorse energetiche," 2024, <https://shop.regalgrid.com/en/snocu-controller.html> [Accessed: 04/2024].
- [9] "Rose energy community," 2024, <https://energy.mapsgroup.it/rose-la-piattaforma-cloud-per-una-gestione-intelligente-delle-cer/> [Accessed: 04/2024].
- [10] "Er-libra ce - la soluzione per la gestione delle comunità energetiche e dei gruppi di autoconsumo," 2024, <https://algowatt.com/librace/> [Accessed: 04/2024].
- [11] F. Meneghello, M. Calore, D. Zucchetto, M. Polese, and A. Zanella, "IoT: Internet of threats? a survey of practical security vulnerabilities in real iot devices," *IEEE Internet of Things Journal*, vol. 6, no. 5, pp. 8182–8201, 2019.
- [12] H. Pirayesh and H. Zeng, "Jamming attacks and anti-jamming strategies in wireless networks: A comprehensive survey," *IEEE Communications Surveys & Tutorials*, 2022.
- [13] J. P. A. Yaacoub, J. H. Fernandez, H. N. Noura, and A. Chehab, "Security of power line communication systems: issues, limitations and existing solutions," *Computer Science Review*, vol. 39, p. 100331, 2021.
- [14] K. Chen, S. Zhang, Z. Li, Y. Zhang, Q. Deng, S. Ray, and Y. Jin, "Internet-of-things security and vulnerabilities: Taxonomy, challenges, and practice," *Journal of Hardware and Systems Security*, vol. 2, no. 2, pp. 97–110, 2018.

**TABLE 3. Security Requirements for Security Level Target 3**

| FR                                             | SR                                                                                  | Countermeasure |
|------------------------------------------------|-------------------------------------------------------------------------------------|----------------|
| FR 1 Identification and authentication control | 1.1 RE 2 Human User multifactor authentication for untrusted networks               | B.3; C.2; C.3  |
|                                                | 1.2 RE 1 Software Processes unique identification and authentication                | B.3; C.2; C.3  |
|                                                | 1.3 RE 1 Unified account management                                                 | B.3; C.3       |
|                                                | 1.4 Identifier management                                                           | B.3; C.2; C.3  |
|                                                | 1.5 RE 1 Hardware security for software process identity credentials                | C.2            |
|                                                | 1.6 RE 1 Unique identification and authentication for Wireless Access               | A.2            |
|                                                | 1.7 RE 1 Password generation and lifetime restrictions for human users              | C.2            |
|                                                | 1.8 Public key infrastructure (PKI) certificates                                    | B.1; C.2       |
|                                                | 1.9 RE 1 Hardware security for public key authentication                            | B.1; C.2       |
|                                                | 1.10 Authenticator feedback                                                         | B.1            |
|                                                | 1.11 Unsuccessful login attempts                                                    | B.3            |
|                                                | 1.12 System use notification                                                        | B.3            |
|                                                | 1.13 RE 1 Explicit access request approval                                          | B.3; C.3       |
| FR 2 – Use control                             | 2.1 RE 3 Supervisor override                                                        | C.2; C.3       |
|                                                | 2.2 RE 1 Identify and report unauthorized wireless devices                          | A.2            |
|                                                | 2.3 RE 1 Identifier management                                                      | C.3            |
|                                                | 2.4 RE 1 Mobile code integrity check                                                | C.3            |
|                                                | 2.5 Session lock                                                                    | C.3            |
|                                                | 2.6 Remote session termination                                                      | C.3            |
|                                                | 2.7 Concurrent session control                                                      | C.3            |
|                                                | 2.8 RE 1 Centrally managed, system-wide audit trail                                 | D.1; D.3       |
|                                                | 2.9 RE 1 Warn when auditing record storage capacity threshold reached               | D.1            |
|                                                | 2.10 Response to audit processing failures                                          | D.1            |
|                                                | 2.11 RE 1 Internal time synchronization                                             | C.2            |
|                                                | 2.12 Non-repudiation                                                                | C.3            |
| FR 3 – System integrity                        | 3.1 RE 1 Cryptographic integrity protection                                         | B.2            |
|                                                | 3.2 RE 2 Central management and reporting for malicious code protection             | C.2; D.1; D.3  |
|                                                | 3.3 RE 1 Automated mechanisms for security functionality verification               | D.1            |
|                                                | 3.4 RE 1 Automated notification about integrity violations                          | D.1            |
|                                                | 3.5 Input validation                                                                | B.2            |
|                                                | 3.6 Deterministic output                                                            | C.1            |
|                                                | 3.7 Error handling                                                                  | C.1            |
|                                                | 3.8 RE 2 Unique session ID generation                                               | B.1            |
|                                                | 3.9 Protection of audit information                                                 | D.1            |
| FR 4 – Data confidentiality                    | 4.1 RE 1 Protection of confidentiality at rest or in transit via untrusted networks | B.1; B.2; B.3  |
|                                                | 4.2 RE 1 Purging of shared memory resources                                         | C.3            |
|                                                | 4.3 Use of cryptography                                                             | B.1; B.2; B.3  |
| FR 5 – Restricted data flow                    | 5.1 RE 2 Independence from non-control system networks                              | C.1; C.2       |
|                                                | 5.2 RE 2 Island mode + 5.2 RE 3 Fail close                                          | C.1; C.2; C.3  |
|                                                | 5.3 RE 1 Prohibit all general purpose person-to-person communications               | C.2            |
|                                                | 5.4 Application partitioning                                                        | C.1; C.2; C.3  |
| FR 6 – Timely response to events               | 6.1 RE 1 Programmatic access to audit logs                                          | D.1; D.3       |
|                                                | 6.2 Continuous monitoring                                                           | D.3            |
| FR 7 – Resource availability                   | 7.1 RE 2 Limit DoS effects to other systems or networks                             | C.1            |
|                                                | 7.2 Resource management                                                             | C.1; C.2       |
|                                                | 7.3 RE 2 Backup automation                                                          | C.2            |
|                                                | 7.4 Control system recovery and reconstitution                                      | C.2            |
|                                                | 7.5 Emergency power                                                                 | C.2            |
|                                                | 7.6 RE 1 Machine-readable reporting of current security settings                    | D.1            |
|                                                | 7.7 Least functionality                                                             | C.2            |
|                                                | 7.8 Control system component inventory                                              | D.1            |

- [15] M. R. Asghar, G. Dán, D. Miorandi, and I. Chlamtac, "Smart meter data privacy: A survey," *IEEE Communications Surveys & Tutorials*, vol. 19, no. 4, pp. 2820–2835, 2017.
- [16] A. Reinhardt, F. Englert, and D. Christin, "Averting the privacy risks of smart metering by local data preprocessing," *Pervasive and Mobile Computing*, vol. 16, pp. 171–183, 2015.
- [17] M. B. Gough, S. F. Santos, T. AlSkaif, M. S. Javadi, R. Castro, and J. P. Catalão, "Preserving privacy of smart meter data in a smart grid environment," *IEEE Transactions on Industrial Informatics*, vol. 18, no. 1, pp. 707–718, 2021.
- [18] R. Bhattarai, S. J. Hossain, J. Qi, J. Wang, and S. Kamalasadan, "Sustained system oscillation by malicious cyber attacks on distributed energy resources," in *2018 IEEE power & energy society general meeting (PESGM)*. IEEE, 2018, pp. 1–5.
- [19] M. Tuttle, M. Poshtan, T. Taufik, and J. Callenes, "Impact of cyber-attacks on power grids with distributed energy storage systems," in *2019 IEEE International Conference on Communications, Control, and Computing Technologies for Smart Grids (SmartGridComm)*. IEEE, 2019, pp. 1–6.
- [20] P. Linnartz, A. Winkens, and S. Simon, "A method for assessing the impact of cyber attacks manipulating distributed energy resources on stable power system operation," in *2021 IEEE PES Innovative Smart Grid Technologies Europe (ISGT Europe)*. IEEE, 2021, pp. 01–05.
- [21] O. G. M. Khan, E. El-Saadany, A. Youssef, and M. Shaaban, "Impact of electric vehicles botnets on the power grid," in *2019 IEEE Electrical Power and Energy Conference (EPEC)*, 2019, pp. 1–5.
- [22] F. Nisar, G. Ramachandran, M. Vilathgamuwa, and R. Jurdak, "Manipulation of actual demand in electric vehicles (mad ev): A cyber-security perspective," in *2022 IEEE 7th Southern Power Electronics Conference (SPEC)*, 2022, pp. 1–8.
- [23] J. Johnson, B. Anderson, B. Wright, J. Quiroz, T. Berg, R. Graves, J. Daley, K. Phan, M. Kunz, R. Pratt, T. Carroll, L. R. O'Neil, B. Dindlebeck, P. Maloney, J. O'Brien, D. Gotthold, R. Varriale, T. Bohn, and K. Hardy, "Cybersecurity for electric vehicle charging infrastructure," 7 2022. [Online]. Available: <https://www.osti.gov/biblio/1877784>

**TABLE 4. Security Requirements for Security Level Target 2**

| FR                                             | SR                                                                                      | Countermeasure |
|------------------------------------------------|-----------------------------------------------------------------------------------------|----------------|
| FR 1 Identification and authentication control | 1.1 RE 1 Human User unique identification and authentication                            | C.3            |
|                                                | 1.2 Software process and device identification and authentication                       | C.3            |
|                                                | 1.3 Account management                                                                  | C.3            |
|                                                | 1.4 Identifier management                                                               | C.3            |
|                                                | 1.5 Authenticator management                                                            | C.3            |
|                                                | 1.6 RE 1 Unique identification and authentication for Wireless Access                   | A.2            |
|                                                | 1.7 Strength of password-based authentication                                           | C.4            |
|                                                | 1.8 Public key infrastructure (PKI) certificates                                        | C.4            |
|                                                | 1.9 Strength of public key authentication                                               | C.4            |
|                                                | 1.10 Authenticator feedback                                                             | C.4            |
|                                                | 1.11 Unsuccessful login attempts                                                        | C.4            |
|                                                | 1.12 System use notification                                                            | C.4            |
|                                                | 1.13 RE 1 Explicit access request approval                                              | C.4            |
| FR 2 – Use control                             | 2.1 RE 1 Authorization enforcement for all users + 2.1 RE 2 Permission mapping to roles | A.3            |
|                                                | 2.2 Wireless use control                                                                | A.2            |
|                                                | 2.3 Use control for portable and mobile devices                                         | C.3            |
|                                                | 2.4 Mobile code                                                                         | C.3            |
|                                                | 2.5 Session lock                                                                        | C.4            |
|                                                | 2.6 Remote session termination                                                          | C.4            |
|                                                | 2.8 Auditable events                                                                    | D.2            |
|                                                | 2.9 Audit storage capacity                                                              | D.2            |
|                                                | 2.10 Response to audit processing failures                                              | D.2            |
|                                                | 2.11 Timestamps                                                                         | D.2            |
| FR 3 – System integrity                        | 3.1 Communication integrity                                                             | A.1            |
|                                                | 3.2 RE 1 Malicious code protection on entry and exit points                             | A.3            |
|                                                | 3.3 Security functionality verification                                                 | D.2; D.3       |
|                                                | 3.4 Software and information integrity                                                  | D.2; D.3       |
|                                                | 3.5 Input validation                                                                    | C.4            |
|                                                | 3.6 Deterministic output                                                                | A.1            |
|                                                | 3.7 Error handling                                                                      | D.2            |
|                                                | 3.8 Session integrity                                                                   | C.3            |
|                                                | 3.9 Protection of audit information                                                     | D.2; D.3       |
| FR 4 – Data confidentiality                    | 4.1 RE 1 Protection of confidentiality at rest or in transit via untrusted networks     | B.2            |
|                                                | 4.2 Information persistence                                                             | B.1            |
|                                                | 4.3 Use of cryptography                                                                 | C.4            |
| FR 5 – Restricted data flow                    | 5.1 RE 1 Physical network segmentation                                                  | A.1            |
|                                                | 5.2 RE 1 Deny by default, allow by exception                                            | A.3            |
|                                                | 5.3 General purpose person-to-person communication restrictions                         | A.3; C.3       |
|                                                | 5.4 Application partitioning                                                            | A.1; A.3       |
| FR 6 – Timely response to events               | 6.1 Audit log accessibility                                                             | D.2            |
|                                                | 6.2 Continuous monitoring                                                               | D.2; D.3       |
| FR 7 – Resource availability                   | 7.1 RE 1 Manage communication loads                                                     | A.3            |
|                                                | 7.2 Resource management                                                                 | C.4            |
|                                                | 7.3 RE 1 Backup verification                                                            | N.A.           |
|                                                | 7.4 Control system recovery and reconstitution                                          | N.A.           |
|                                                | 7.5 Emergency power                                                                     | N.A.           |
|                                                | 7.6 Network and security configuration settings                                         | A.1            |
|                                                | 7.7 Least functionality                                                                 | A.3            |
|                                                | 7.8 Control system component inventory                                                  | D.2            |

- [24] Y. Dvorkin and S. Garg, "Iot-enabled distributed cyber-attacks on transmission and distribution grids," in *2017 North American Power Symposium (NAPS)*, 2017, pp. 1–6.
- [25] T. Nasr, S. Torabi, E. Bou-Harb, C. Fachkha, and C. Assi, "Power jacking your station: In-depth security analysis of electric vehicle charging station management systems," *Computers & Security*, vol. 112, p. 102511, 2022. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0167404821003357>
- [26] G. S. Morrison, "Threats and mitigation of ddos cyberattacks against the u.s. power grid via ev charging," 2018.
- [27] S. Deb, K. Tammi, K. Kalita, and P. Mahanta, "Impact of electric vehicle charging station load on distribution network," *Energies*, vol. 11, no. 1, 2018. [Online]. Available: <https://www.mdpi.com/1996-1073/11/1/178>
- [28] A. Mokarim, G. B. Gaggero, and M. Marchese, "Evaluation of the impact of cyber-attacks against electric vehicle charging stations in a low voltage distribution grid," in *2023 IEEE International Conference on Communications, Control, and Computing Technologies for Smart Grids (SmartGridComm)*. IEEE, 2023, pp. 1–7.
- [29] —, "Impact analysis of cyber attacks against energy communities in distribution grids," *Electronics*, vol. 13, no. 9, p. 1709, 2024.
- [30] K. Stouffer, J. Falco, and K. Scarfone, "Guide to industrial control systems (ics) security - supervisory control and data acquisition (scada) systems, distributed control systems (dcs), and other control system configurations such as programmable logic controllers (plc)," 2011-06-07 2011.
- [31] R. Leszczyna, "Cybersecurity and privacy in standards for smart grids—a comprehensive survey," *Computer Standards & Interfaces*, vol. 56, pp. 62–73, 2018.
- [32] M. Stojkov, N. Dalčević, B. Markoski, B. Milosavljević, and G. Sladić, "Towards cross-standard compliance readiness: Security requirements model for smart grid," *Energies*, vol. 14, no. 21, p. 6862, 2021.
- [33] S. M. Khalil, H. Bahsi, H. Ochieng'Dola, T. Korötko, K. McLaughlin, and V. Kotkas, "Threat modeling of cyber-physical systems-a case study of a microgrid system," *Computers & Security*, vol. 124, p. 102950, 2023.
- [34] G. Gkoktsis, H. Lauer, and L. Jäger, "Risk assessments in virtual power plants with nescor criteria, practical application, advantages and disadvantages," in *Proceedings of the 18th International Conference on Availability, Reliability and Security*, 2023, pp. 1–11.
- [35] J. Rintala, M. Loukkalahti, S. Musunuri, J. Haapaniemi, and C. Hampel,



- "Is the cybersecurity standard IEC 62443 applicable to distribution substations?" in *27th International Conference on Electricity Distribution (CIRED 2023)*, vol. 2023. IET, 2023, pp. 1554–1558.
- [36] J. B. Heluany and R. Galvão, "Iec 62443 standard for hydro power plants," *Energies*, vol. 16, no. 3, p. 1452, 2023.
- [37] S. Dong, J. Cao, D. Flynn, and Z. Fan, "Cybersecurity in smart local energy systems: requirements, challenges, and standards," *Energy Informatics*, vol. 5, no. 1, p. 9, 2022.
- [38] J. Johnson and I. Hanke, "Recommendations for distributed energy resource patching," Sandia National Lab.(SNL-NM), Albuquerque, NM (United States); SMA Solar . . . , Tech. Rep., 2021.
- [39] I. Zografopoulos, N. D. Hatziaargyriou, and C. Konstantinou, "Distributed energy resources cybersecurity outlook: Vulnerabilities, attacks, impacts, and mitigations," *IEEE Systems Journal*, 2023.
- [40] Y. Wu, Y. Wu, H. Cimen, J. C. Vasquez, and J. M. Guerrero, "Towards collective energy community: Potential roles of microgrid and blockchain to go beyond p2p energy trading," *Applied Energy*, vol. 314, p. 119003, 2022.
- [41] N. Mhaisen, N. Fetais, and A. Massoud, "Secure smart contract-enabled control of battery energy storage systems against cyber-attacks," *Alexandria Engineering Journal*, vol. 58, no. 4, pp. 1291–1300, 2019.
- [42] Z. Guan, G. Si, X. Zhang, L. Wu, N. Guizani, X. Du, and Y. Ma, "Privacy-preserving and efficient aggregation based on blockchain for power grid communications in smart communities," *IEEE Communications Magazine*, vol. 56, no. 7, pp. 82–88, 2018.
- [43] P. Mousavi, M. S. Ghazizadeh, and V. Vahidinasab, "A decentralized blockchain-based energy market for citizen energy communities," *Inventions*, vol. 8, no. 4, p. 86, 2023.
- [44] T. Cioara, L. Todorean, D. Mitrea, V. Chifu, M. Antal, I. Anghel, V. Croce, M. Bertoni, and F. Nucci, "Decentralized demand response in energy communities using blockchain," in *2022 Workshop on Blockchain for Renewables Integration (BLORIN)*. IEEE, 2022, pp. 7–12.
- [45] S. Cheung, B. Dutertre, M. Fong, U. Lindqvist, K. Skinner, and A. Valdes, "Using model-based intrusion detection for SCADA networks," in *Proceedings of the SCADA security scientific symposium*, vol. 46. Citeseer, 2007, pp. 1–12.
- [46] A. Chavez, C. Lai, N. Jacobs, S. Hossain-McKenzie, C. Jones, J. Johnson, and A. Summers, "Hybrid intrusion detection system design for distributed energy resource systems," in *2019 IEEE CyberPELS (CyberPELS)*. IEEE, 2019, pp. 1–6.
- [47] J. Giraldo, D. Urbina, A. Cardenas, J. Valente, M. Faisal, J. Ruths, N. O. Tippenhauer, H. Sandberg, and R. Candell, "A survey of physics-based attack detection in cyber-physical systems," *ACM Computing Surveys (CSUR)*, vol. 51, no. 4, pp. 1–36, 2018.
- [48] G. B. Gaggero, A. Mokarim, P. Girdinio, and M. Marchese, "Should we include cyberdefense functionalities in electrical power system protections?: A proposed approach," *IEEE Industrial Electronics Magazine*, 2024.



**ALESSANDRO ARMELLIN** is currently a Ph.D. student at the Satellite Communications and Heterogeneous Networking Laboratory (SCNL) at the University of Genoa and he collaborates with IREN SpA that is a relevant Italian energy company. He got his Master's degree in Electrical Engineering at the University of Genoa in March 2021. His main research activities concern cybersecurity of Industrial Control Systems, Microgrids and Smart Grids.



**PAOLA GIRDINIO** Full Professor of Electrotechnics at the Faculty of Engineering, University of Genoa, where she was formerly Dean of the Faculty, is currently Chair of the Center of Competence for Security and Optimization of Strategic Infrastructure 4.0 (Start 4.0). She has served as a board member of ENEL, the Costa Crociere Foundation, Ansaldo STS, Banca Carige, Ansaldo Energia, D'Appolonia (RINA Group) and the University of Genoa. She is also a member of the board of directors of Ansaldo Energia, WSENSE of the scientific committee of the Eurispes Security Observatory, a member of the technical committee of the AZIMU infrastructure fund, and was selected in the 2018 European awards short list BCI. For her commitment in academic and professional spheres, she was included in the roll of experts in technological innovation established by the Italian Ministry of Economic Development.



**MARIO MARCHESE** (S'94–M'97–SM'04) got his "Laurea" degree cum laude in 1992 and his Ph.D. degree in "Telecommunications" at the University of Genoa in 1997. From 1999 to January 2005, he worked with the Italian Consortium of Telecommunications (CNIT) where he was Head of Research. From February 2005 to January 2016 he was Associate Professor and since February 2016 he has been Full Professor at the University of Genoa where now is Vice-Rector to Doctoral Studies and Relations with Companies. He is the author of the book "Quality of Service over Heterogeneous Networks", John Wiley & Sons, Chichester, 2007, and author/co-author of more than 300 scientific works, including international magazines, international conferences and book chapters. The most important contribution of Mario Marchese's scientific activity is in the field of: Networking, Quality of Service over Heterogeneous Networks, Satellite Networks, Network Security, Critical Infrastructure Security and Intrusion Detection Systems.



**GIOVANNI GAGGERO** (S'19–M'22) is currently Assistant Professor at the Satellite Communications and Heterogeneous Networking Laboratory at the University of Genoa. He is also CEO of the spinoff of university of Genova AirFIELD Security srl. He got his MSc degree in electrical engineering and his Ph.D. degree in Electronic and Telecommunication engineering at the University of Genoa. His main research activity concerns Network Security of Industrial Control Systems,

Microgrids, and Smart Grids.

...